
AWS WAF (Web Application Firewall) - Detailed Documentation

What is AWS WAF?

AWS WAF is a **web application firewall** that helps protect your web applications from **common web exploits** and **vulnerabilities** that could affect application availability, compromise security, or consume excessive resources.

AWS WAF is deployed **in front of web applications** and filters HTTP(S) traffic based on **defined rules**.

Key Features

Feature	Description
 Rule-based filtering	Create custom rules to allow, block, or count requests.
 Geographic restrictions	Block traffic from specific countries.
 Rate-based rules	Limit request rates from specific IPs (e.g., prevent DDoS).
 Bot Control	Detect and mitigate bad bots.
 Managed Rules	Use AWS or partner rule groups (e.g., OWASP top 10).
 Real-time metrics	Integrated with Amazon CloudWatch for monitoring.
 Logging & visibility	Logs to Amazon S3, CloudWatch Logs, or Kinesis.

Core Components of AWS WAF

1. Web ACL (Access Control List)

- The central configuration unit of WAF.

- Contains a set of **rules** that define how to inspect and handle requests.

2. Rules & Rule Groups

- **Rules:** Define specific inspection criteria (e.g., block IPs, match header values).
- **Rule Groups:** Logical collections of rules; can be AWS-managed or custom.

3. Conditions/Statements

Each rule contains **statements** such as:

- **IP match**
- **Geo match**
- **String match** (Header, body, URI)
- **Size constraints**
- **SQL injection detection**
- **Cross-site scripting (XSS) match**
- **Regex pattern match**

4. Actions

Each rule or Web ACL must define an action:

- **Allow**
- **Block**
- **Count** (used for monitoring/test)

Where Can You Use AWS WAF?

AWS WAF can be attached to:

AWS Resource	Use Case
Amazon CloudFront	Protect content delivered via CDN.
Application Load Balancer (ALB)	Filter traffic to apps hosted on EC2, ECS, etc.
Amazon API Gateway	Secure REST APIs.
AWS App Runner	Protect containerized applications.

Creating WAF from AWS Console (GUI)

Step-by-Step Guide:

1. Navigate to AWS WAF

- Go to AWS Console → Search "WAF" → Open **AWS WAF & Shield**

2. Create a Web ACL

- Click **Create Web ACL**
- Name: `my-web-acl`
- Region: Choose the same as ALB or Global for CloudFront
- Associated Resource: e.g., ALB or CloudFront distribution

3. Add Rules

You can:

-  Add **managed rule groups** (e.g., AWS OWASP Core)
-  Create your own custom rules (example below)

4. Example Rule: Block IP

- Rule Name: **block-bad-ip**
- Rule Type: **IP set match**
- Create an **IP Set** with bad IPs to block.
- Action: **Block**

5. Set Default Action

- Choose what to do if no rules match: **Allow** or **Block**.

6. Configure Logging (Optional)

- Enable logging to **S3**, **CloudWatch**, or **Kinesis** for analysis.

7. Review & Create

Once created, WAF starts inspecting traffic based on rules.

Managed Rule Groups (OWASP Top 10)

AWS provides pre-configured rules for common attack vectors:

Rule Group	Description
AWSManagedRulesCommonRuleSet	Protects against known bad inputs.

`AWSManagedRulesSQLiRuleSet` SQL injection protection.

`AWSManagedRulesXSSRuleSet` Cross-site scripting protection.

`AWSManagedRulesBotControlRuleSet` Detect bots & automation.

Use these to quickly enable protection with minimal configuration.

Monitoring & Logging

Metrics:

- Integrated with **Amazon CloudWatch**
- Track allowed, blocked, counted requests

Logging:

- Enable WAF logs to:
 - **Amazon S3**
 - **CloudWatch Logs**
 - **Amazon Kinesis**

Example log output:

```
{
  "timestamp": "2025-06-12T12:00:00Z",
  "action": "BLOCK",
  "ruleGroup": "AWSManagedRulesCommonRuleSet",
  "uri": "/login",
  "sourceIp": "203.0.113.10"
}
```

Common Use Cases

Use Case	Example
 Block specific IPs	Block known attacker IPs or ranges
 Geo-blocking	Block access from specific countries
 Rate limiting	Prevent brute-force login attacks
 Bot mitigation	Detect bad bots or scrapers
 OWASP protection	Automatically block common app exploits

Pricing Overview

- Charged based on:
 - Number of **Web ACLs**
 - Number of **Rules**
 - Number of **Requests inspected**

Estimate via: [AWS WAF Pricing Calculator](#)

Best Practices

1.  **Start with Count mode** before blocking
2.  Use **Managed Rule Sets** to cover common threats

3.  Regularly test and validate your rules
 4.  Monitor traffic with CloudWatch logs
 5.  Use rate-based rules to stop brute-force attacks
 6.  Enable **logging** for auditing and forensics
-

Hands-On Lab Ideas for Students

1. **Create a Web ACL to block IPs and test with curl**
 2. **Use AWS Managed Rules and monitor blocked traffic**
 3. **Attach WAF to API Gateway and inspect logs**
 4. **Simulate SQL injection and observe WAF actions**
 5. **Enable and analyze WAF logs in S3**
-